CRISC Exam - Domain 4: Technology & Security

Technology Risk Questions with Explanations

Compiled from ISACA CRISC Review Manual 8th Edition

October 19, 2026

Outline

1. Technology Roadmaps & Enterprise Architecture

2. Operations Management: Hardware, Software & Networks

Q1: Purpose of Enterprise Architecture

Question

What is the PRIMARY purpose of developing an enterprise architecture (EA)?

A. To document all hardware and software assets

B. To deliver a view of the current state of IT, establish a future-state vision, and generate a strategy to move between them

C. To replace the need for a risk assessment

D. To satisfy regulatory audit requirements

Q1: Explanation

Correct Answer: B

Enterprise architecture delivers a view of the current state of IT, establishes a vision for a future state, and generates a strategy to move from current to future conditions that minimizes business disruption.

Option Analysis

- **A** - **Incorrect:** An asset inventory is only one component
- **B** - **Correct:** EA frames how information enables the organization
- **C** - **Incorrect:** EA complements, not replaces, risk assessment
- **D** - **Incorrect:** Compliance is a secondary benefit

Q2: EA Framework Key Topics

Question

All EA frameworks provide structured guidance across which four key topics?

A. Budgeting, staffing, training, and auditing
B. Documentation, notation, process, and organization
C. Hardware, software, networks, and data
D. Identify, assess, respond, and monitor

Q2: Explanation

Correct Answer: B

All EA frameworks provide structured guidance across four key topics: documentation, notation, process, and organization.

Option Analysis

- **A - Incorrect:** These are management activities
- **B - Correct:** Documentation, notation, process, organization
- **C - Incorrect:** These are technology domains
- **D - Incorrect:** These are risk management phases

Q3: Technology Roadmap Purpose

Question

What is the purpose of a technology roadmap?

A. To list all current IT projects

B. To link short- and long-term business goals with specific technology solutions

C. To document the IT organizational chart

D. To record all IT incidents

Q3: Explanation

Correct Answer: B

A technology roadmap is the planning process that links new short- and long-term goals identified by the EA with specific technology solutions.

Option Analysis

- **A - Incorrect:** A project list is not a roadmap
- **B - Correct:** Roadmaps link goals to technology solutions
- **C - Incorrect:** Org charts are unrelated to roadmaps
- **D - Incorrect:** Incident records are operational data

Q4: Risk Without Enterprise Architecture

Question

In environments where an EA is either immature or absent, what should the risk practitioner do?

A. Suspend all risk management activities until an EA is built

B. Place greater emphasis on technology-specific assessments to build a piecemeal vision of current IT risk

C. Rely solely on qualitative risk assessments

D. Delegate all risk assessment to the IT department

Q4: Explanation

Correct Answer: B

Where an EA is immature or absent, the risk practitioner must place greater emphasis on technology-specific assessments to build a piecemeal vision of current IT risk.

Option Analysis

- **A - Incorrect:** Risk management cannot be suspended
- **B - Correct:** Technology-specific assessments fill the gap
- **C - Incorrect:** Qualitative assessment alone is insufficient
- **D - Incorrect:** Risk management is an enterprise responsibility

Q5: Maturity Model Purpose

Question

What is the goal of a maturity model in the context of enterprise architecture?

- A To dictate exactly how processes should be performed
- B To define what outcomes are desirable and help organizations gauge progress against published baselines
- C To replace internal audits
- D To certify compliance with regulations

Q5: Explanation

Correct Answer: B

The goal of maturity models is not to dictate how something should be done but rather what outcomes are desirable, helping organizations gauge their progress.

Option Analysis

- **A - Incorrect:** Maturity models focus on outcomes, not prescriptive steps
- **B - Correct:** They define desirable outcomes
- **C - Incorrect:** They do not replace audits
- **D - Incorrect:** They are not certification mechanisms

Q6: Hardware Risk Areas

Question

Which of the following is an area of concern associated with hardware?

A. Logic flaws or semantic errors
B. Use of default credentials and unnecessary services
C. Inadequate data validation
D. Lack of version control

Q6: Explanation

Correct Answer: B

Hardware concerns include obsolescence, poor maintenance, misconfiguration, use of default credentials, unnecessary services, physical loss, insecure disposal, and component failure.

Option Analysis

- **A - Incorrect:** Logic flaws are a software concern
- **B - Correct:** Default credentials are a hardware concern
- **C - Incorrect:** Data validation is a software concern
- **D - Incorrect:** Version control is a software concern

Q7: Supply Chain Hardware Risk

Question

What should organizations do to mitigate the risk of purchasing hardware infected with security vulnerabilities during manufacturing or delivery?

A. Purchase only from the lowest-cost vendor

B. Use trusted vendors or suppliers and validate maintenance hooks

C. Rely solely on vendor self-attestation

D. Avoid all hardware purchases

Q7: Explanation

Correct Answer: B

Risk practitioners should encourage use of trusted vendors and validate that maintenance hooks are documented and either secured or eliminated.

Option Analysis

- **A - Incorrect:** Lowest cost may increase risk
- **B - Correct:** Trusted vendors and validated hooks
- **C - Incorrect:** Self-attestation is insufficient
- **D - Incorrect:** Avoiding all hardware is impractical

Q8: Operating System Risk Areas

Question

Which of the following is a concern specific to operating systems?

- A Kernel-level vulnerabilities such as rootkits and hypervisor escapes
- B Poor physical access controls
- C Inadequate HVAC systems
- D Cable exceeding approved length

Q8: Explanation

Correct Answer: A

OS concerns include unpatched vulnerabilities, buffer overflows, misconfiguration, weak access controls, and kernel-level vulnerabilities such as rootkits and hypervisor escapes.

Option Analysis

- **A - Correct:** Kernel-level vulnerabilities are OS concerns
- **B - Incorrect:** Physical access is an environmental control
- **C - Incorrect:** HVAC is an environmental control
- **D - Incorrect:** Cabling is a network concern

Q9: Patch Management Lesson

Question

The 2024 CrowdStrike global outage best illustrates which risk?

A. The need to avoid all software updates
B. The importance of not skipping testing and patch management processes
C. The risk of using cloud services
D. The danger of open-source software

Q9: Explanation

Correct Answer: B

Root cause analysis discovered the update had not undergone routine patch management processes. Testing should not be skipped to expedite patching.

Option Analysis

- **A - Incorrect:** Avoiding updates leaves systems vulnerable
- **B - Correct:** Testing before deployment is essential
- **C - Incorrect:** This was not cloud-specific
- **D - Incorrect:** This was a commercial product

Q10: Application Risk from Updates

Question

In mobile computing, why can application updates introduce risk?

A. Updates always improve security

B. A major version release may change or remove functionality, and vendors may end support for prior versions

C. Updates are always optional

D. Updates never affect functionality

Q10: Explanation

Correct Answer: B

A major version release may change or remove functionality. Vendors may end support for prior versions, causing sudden loss of features that impact production.

Option Analysis

- **A - Incorrect:** Updates can introduce new risk
- **B - Correct:** Functionality may change or be removed
- **C - Incorrect:** Updates may be effectively mandatory
- **D - Incorrect:** Updates frequently affect functionality

Q11: Database Security Controls

Question

Which of the following is a method for providing database security?

- (A) Placing database servers directly on the internet
- (B) Encryption of sensitive data in the database and restricting administrator-level access
- (C) Disabling all backups
- (D) Allowing unrestricted access to all tables

Q11: Explanation

Correct Answer: B

Database security is provided through encryption of sensitive data, use of database views, secure protocols, content-based access controls, restricting administrator-level access, and backups. Database servers should not be directly accessible from outside.

Option Analysis

- **A** - **Incorrect:** Direct internet exposure is a major risk
- **B** - **Correct:** Encryption and restricted admin access
- **C** - **Incorrect:** Backups are essential
- **D** - **Incorrect:** Unrestricted access violates least privilege

Q12: Software Utilities Risk

Question

Why are compromised device drivers a significant risk?

A. They only affect printer functionality

B. They can alter intended commands to yield different results or fail to deliver instructions

C. They are always digitally signed and trusted

D. They have no interaction with hardware

Q12: Explanation

Correct Answer: B

Compromised drivers may interfere with proper operations of hardware by altering intended commands to yield different results or failing to deliver instructions.

Option Analysis

- **A - Incorrect:** Drivers affect all hardware
- **B - Correct:** Compromised drivers can alter commands
- **C - Incorrect:** Digital signing does not guarantee safety
- **D - Incorrect:** Drivers bridge software and hardware

Q13: Environmental Controls - Power

Question

Which of the following is an area of concern associated with power environmental controls?

- A Clogged filters
- B Surges, spikes, sags, brownouts, and generator latency
- C High humidity causing corrosion
- D Low humidity causing static

Q13: Explanation

Correct Answer: B

Power concerns include surges, spikes, sags, brownouts, and faults, plus generator latency or spin-up time.

Option Analysis

- **A - Incorrect:** Clogged filters are an HVAC concern
- **B - Correct:** Power effects
- **C - Incorrect:** High humidity is an HVAC concern
- **D - Incorrect:** Low humidity is an HVAC concern

Q14: Firewall Configuration Review

Question

Which provides the BEST assurance that a firewall is configured in compliance with an enterprise's security policy?

A. Reviewing actual procedures
B. Interviewing the firewall administrator
C. Reviewing parameter settings
D. Reviewing the log file for recent attacks

Q14: Explanation

Correct Answer: C

A review of the parameter settings provides a good basis for comparison of the actual configuration to the security policy.

Option Analysis

- **A - Incorrect:** Procedures describe intent
- **B - Incorrect:** Interviews do not confirm configuration
- **C - Correct:** Parameter settings show actual configuration
- **D - Incorrect:** Logs show activity, not configuration

Q15: Firewall Log Review

Question

Why should firewall logs be regularly reviewed?

A. To detect suspicious activity and verify logging is functioning
B. To update the firewall's configuration automatically
C. To replace the need for an intrusion detection system
D. To calculate the firewall's annual loss expectancy

Q15: Explanation

Correct Answer: A

Firewall logs should be regularly reviewed to detect any suspicious activity.

Option Analysis

- **A - Correct:** Logs are reviewed to detect suspicious activity
- **B - Incorrect:** Log review does not update configuration
- **C - Incorrect:** Logs complement, not replace, IDS
- **D - Incorrect:** ALE is calculated from asset value

Q16: Proxy Function

Question

What is the role of a proxy in a network?

A. To act as an intermediary between two communicating parties
B. To permanently store all network traffic
C. To replace the need for a firewall
D. To assign IP addresses to network devices

Q16: Explanation

Correct Answer: A

A proxy acts as an intermediary, presenting itself to each side as if it were the other end. This allows filtering and examination of suspicious activity.

Option Analysis

- **A - Correct:** Intermediary
- **B - Incorrect:** Proxies filter, not store
- **C - Incorrect:** Proxies complement firewalls
- **D - Incorrect:** DHCP assigns IP addresses

Q17: IDS vs. IPS

Question

What is the key difference between an IDS and an IPS?

- A. An IDS is more expensive than an IPS
- B. An IDS detects and alerts, while an IPS detects and blocks traffic in-line
- C. An IPS has no effect on network throughput
- D. An IDS must be placed in the line of traffic

Q17: Explanation

Correct Answer: B

An IDS alerts without affecting throughput. An IPS combines detection with blocking and must be placed in-line, generally slowing the network.

Option Analysis

- **A - Incorrect:** Cost is not the differentiator
- **B - Correct:** IDS alerts; IPS blocks in-line
- **C - Incorrect:** An IPS generally slows throughput
- **D - Incorrect:** An IPS, not an IDS, is in-line

Q18: DNS Risk

Question

Which of the following is a security risk associated with the Domain Name System (DNS)?

- A DNS replies can be used in amplification attacks to flood a victim's system
- B DNS encrypts all network traffic
- C DNS replaces the need for IP addressing
- D DNS prevents all man-in-the-middle attacks

Q18: Explanation

Correct Answer: A

False DNS replies can misroute traffic, and DNS replies have been used in amplification attacks. Attacks against DNS servers can impede name resolution.

Option Analysis

- **A - Correct:** DNS amplification attacks are a known risk
- **B - Incorrect:** DNS does not encrypt traffic
- **C - Incorrect:** DNS maps names to IP addresses
- **D - Incorrect:** DNS does not prevent MITM attacks

Q19: Rogue Wireless Access Points

Question

Why are rogue wireless access points a significant vulnerability?

- (A) They improve network performance
- (B) They may permit a person to access the network directly without going through a secure device or bypassing firewalls
- (C) They are always detected by antivirus software
- (D) They require no physical access to install

Q19: Explanation

Correct Answer: B

Rogue access points may permit a person to access the network directly, bypassing firewalls or other layers of defense. Wireless discovery scans should be part of the vulnerability assessment process.

Option Analysis

- **A - Incorrect:** They do not improve security
- **B - Correct:** They bypass network security controls
- **C - Incorrect:** Antivirus does not detect rogue APs
- **D - Incorrect:** They usually require physical access

Q20: Mesh Topology

Question

Which network topology provides the highest availability because traffic can route around a failure?

A. Bus
B. Star
C. Ring
D. Mesh

Q20: Explanation

Correct Answer: D

In a mesh topology, many devices are connected to many other devices so traffic can route around a failure. The internet is a partial mesh.

Option Analysis

- **A - Incorrect:** A cut cable in a bus fails all downstream users
- **B - Incorrect:** Loss of central switch in a star affects all
- **C - Incorrect:** A single cut affects a unidirectional ring
- **D - Correct:** Mesh routes around failures

Q21: LAN vs. WAN Protocols

Question

Which protocol type is best suited for a WAN where traffic crosses network borders?

A. Interior gateway protocols (IGPs) such as OSPF
B. Exterior gateway protocols (EGPs) such as BGP
C. Routing Information Protocol (RIP)
D. Enhanced Interior Gateway Routing Protocol (EIGRP)

Q21: Explanation

Correct Answer: B

WANs benefit from EGPs, which are more complex than IGPs. The most widely used EGP is BGP.

Option Analysis

- **A** - **Incorrect:** IGPs are used within a LAN
- **B** - **Correct:** EGPs such as BGP are used for WANs
- **C** - **Incorrect:** RIP is an IGP
- **D** - **Incorrect:** EIGRP is an IGP

Q22: Software-Defined Networking

Question

What is a key benefit of software-defined networking (SDN)?

A. It eliminates the need for network security controls

B. It separates network control and forwarding functions, allowing dynamic shaping of traffic

C. It permanently fixes network configurations

D. It removes the need for a network administrator

Q22: Explanation

Correct Answer: B

SDN separates control and forwarding functions, allowing dynamic traffic shaping to meet business requirements on short notice.

Option Analysis

- **A - Incorrect:** SDN does not eliminate security needs
- **B - Correct:** Dynamic traffic shaping
- **C - Incorrect:** SDN enables dynamic configurations
- **D - Incorrect:** Administrators are still required

Q23: Demilitarized Zone Purpose

Question

What is the purpose of a demilitarized zone (DMZ) in a network?

A. To store critical organizational assets securely
B. To house services intended for outside use, protecting internal systems
C. To replace internal firewalls
D. To host the organization's backup data

Q23: Explanation

Correct Answer: B

The DMZ houses externally facing services in a segment configured to allow open access. Critical assets are kept out of the DMZ.

Option Analysis

- **A - Incorrect:** Critical assets are kept out of the DMZ
- **B - Correct:** DMZ houses externally facing services
- **C - Incorrect:** DMZ complements firewalls
- **D - Incorrect:** Backup data should not be in the DMZ

Q24: VPN Purpose

Question

What is the primary purpose of a virtual private network (VPN)?

A. To make the network faster

B. To logically separate traffic using encrypted tunnels, making it unreadable except by intended recipients

C. To replace firewalls

D. To assign IP addresses

Q24: Explanation

Correct Answer: B

A VPN logically separates data traffic by digitally constructed tunnels, configured with encryption so traffic is unreadable except by intended recipients.

Option Analysis

- **A** - **Incorrect:** VPNs add processing overhead
- **B** - **Correct:** VPNs create encrypted tunnels
- **C** - **Incorrect:** VPNs complement firewalls
- **D** - **Incorrect:** DHCP assigns IP addresses

Q25: Zero Trust Architecture Principle

Question

According to NIST SP 800-207, zero trust focuses on protecting:

A. Network segments
B. Resources rather than network segments
C. Only the perimeter firewall
D. Only internal employees

Q25: Explanation

Correct Answer: B

Zero trust focuses on protecting resources (assets, services, workflows, accounts), not network segments, as the network location is no longer the prime component of the security posture.

Option Analysis

- **A - Incorrect:** Zero trust moves away from segment-based protection
- **B - Correct:** Focuses on protecting resources
- **C - Incorrect:** Perimeter-only protection is opposite of zero trust
- **D - Incorrect:** Applies to all users and assets

Q26: Technology Refresh Considerations

Question

Which of the following is a risk consideration related to technology refresh?

- A Age of equipment and availability of replacement parts
- B The number of employees in the IT department
- C The color scheme of the data center
- D The brand of coffee served in the office

Q26: Explanation

Correct Answer: A

Risk considerations include age of equipment, available expertise, vendor viability, documentation, availability of replacement parts, ability to test, operating environment, patch ability, willingness to change, and vendor lock-in.

Option Analysis

- **A - Correct:** Age and parts availability
- **B - Incorrect:** Not a technology refresh factor
- **C - Incorrect:** Irrelevant
- **D - Incorrect:** Irrelevant

Q27: Legacy System Risk

Question

When legacy systems cannot be replaced, what is the risk practitioner's role?

A. Reject any course of action involving the legacy system

B. Work with the risk owner to reach an acceptable level of risk using compensating controls

C. Mandate immediate replacement regardless of cost

D. Ignore the legacy system since it is unavoidable

Q27: Explanation

Correct Answer: B

Some legacy systems may not be replaceable. The risk practitioner's role is to work with the risk owner to reach an acceptable level of risk using compensating controls such as additional backups, segmentation, and increased monitoring.

Option Analysis

- **A - Incorrect:** Rejection is not the role
- **B - Correct:** Work with risk owner on compensating controls
- **C - Incorrect:** Mandating replacement ignores cost-benefit
- **D - Incorrect:** Ignoring increases risk

Q28: IT Operations Security Problems

Question

Which security problem is commonly seen within the IT department due to complacency?

A. Enforcing strict separation of duties
B. Sharing high-level accounts and passwords and lack of control over changes to production systems
C. Conducting regular vulnerability assessments
D. Maintaining complete documentation

Q28: Explanation

Correct Answer: B

Where complacency reigns, risk ignorance can result in breaches. Common problems include sharing high-level accounts and passwords and lack of control over changes to production.

Option Analysis

- **A** - **Incorrect:** Good practice, not a problem
- **B** - **Correct:** Shared accounts and uncontrolled changes
- **C** - **Incorrect:** Regular assessments are good practice
- **D** - **Incorrect:** Documentation is good practice

Q29: Configuration Management Goal

Question

What is the goal of configuration management?

- (A) To have a single approved way in which systems or devices intended for a particular role should be configured
- (B) To allow each administrator to configure systems as they prefer
- (C) To eliminate all system changes
- (D) To replace the need for change management

Q29: Explanation

Correct Answer: A

A single approved configuration makes it easier to deploy new systems, test patches and upgrades, identify malware, and manage the enterprise.

Option Analysis

- **A - Correct:** Single approved configuration
- **B - Incorrect:** Individual preference creates inconsistency
- **C - Incorrect:** Changes must be controlled, not eliminated
- **D - Incorrect:** Configuration management works with change management

Q30: Hardening Process

Question

What does the hardening process aim to achieve?

- A To install all available software
- B To reduce vulnerability by limiting attack vectors, disabling unnecessary functionality, and changing default credentials
- C To increase the number of open ports
- D To enable all services by default

Q30: Explanation

Correct Answer: B

Hardening reduces vulnerability by limiting attack vectors. Unnecessary ports, services, and protocols are disabled; default accounts and passwords are changed or disabled.

Option Analysis

- **A - Incorrect:** Installing all software increases attack surface
- **B - Correct:** Hardening limits attack vectors
- **C - Incorrect:** Open ports increase vulnerability
- **D - Incorrect:** Unnecessary services should be disabled

Q31: Cloud Computing Essential Characteristic

Question

Which cloud characteristic allows capabilities to be rapidly and elastically provisioned to scale out and rapidly released to scale in?

- A On-demand self-service
- B Broad network access
- C Rapid elasticity
- D Measured service

Q31: Explanation

Correct Answer: C

Rapid elasticity means capabilities can be rapidly and elastically provisioned and released. To the customer, capabilities often appear unlimited and can be purchased in any quantity at any time.

Option Analysis

- **A - Incorrect:** On-demand self-service is automatic provisioning
- **B - Incorrect:** Broad network access is accessibility
- **C - Correct:** Rapid elasticity
- **D - Incorrect:** Measured service is metering

Q32: Cloud Migration Consideration

Question

Which of the following is a common consideration before migrating to a cloud-based environment?

- A Increased visibility and control over operations
- B Reduced visibility and control, unauthorized use and abuse, and provider's privileged insiders
- C Guaranteed unlimited storage at no cost
- D Elimination of all security responsibilities

Q32: Explanation

Correct Answer: B

Common cloud considerations include reduced visibility and control, unauthorized use and abuse, provider's privileged insiders, compromised APIs, multi-tenant separation failures, incomplete data deletion, stolen credentials, vendor lock-in, and insufficient due diligence.

Option Analysis

- **A - Incorrect:** Cloud generally reduces visibility
- **B - Correct:** Key cloud risk considerations
- **C - Incorrect:** Storage is not unlimited or free
- **D - Incorrect:** Organizations retain responsibilities

Q33: Cloud Provider Certification Misconception

Question

What common misconception do organizations have regarding cloud provider certifications?

A. Certifications are always too expensive

B. A cloud provider's certification automatically transfers to the customer's environment

C. Certifications guarantee 100% uptime

D. Certifications eliminate the need for customer controls

Q33: Explanation

Correct Answer: B

A common misconception is that if a cloud provider has a certification, that certification transfers to the customer's environment. This is not the case.

Option Analysis

- **A - Incorrect:** Cost is not the misconception
- **B - Correct:** Certifications do not transfer
- **C - Incorrect:** Certifications do not guarantee uptime
- **D - Incorrect:** Customer controls are still needed

Q34: Big Data Risk - Amplified Impact

Question

Which describes an amplified technical impact risk associated with big data?

- A Data is always more secure when centralized
- B If an unauthorized user gains access to centralized repositories, the entirety of the data is in jeopardy
- C Big data eliminates privacy concerns
- D Big data reduces the need for data governance

Q34: Explanation

Correct Answer: B

Amplified technical impact occurs when an unauthorized user gains access to centralized repositories, putting the entirety of the data in jeopardy. Other risks include privacy concerns and governance challenges.

Option Analysis

- **A** - **Incorrect:** Centralization increases risk
- **B** - **Correct:** Centralized data magnifies breach impact
- **C** - **Incorrect:** Big data increases privacy concerns
- **D** - **Incorrect:** Big data increases governance need

Q35: Large Language Model Risk

Question

What is a key risk associated with large language models (LLMs) and generative AI?

A. They always provide accurate information
B. They can create false information or "hallucinations"
C. They eliminate the need for human oversight
D. They cannot be used for malicious purposes

Q35: Explanation

Correct Answer: B

LLMs have demonstrated a willingness to share information they know is false and the ability to create new assumptions based on erroneous reasoning, referred to as "hallucinations."

Option Analysis

- **A - Incorrect:** LLMs can be inaccurate
- **B - Correct:** Hallucinations are a key risk
- **C - Incorrect:** Human oversight remains essential
- **D - Incorrect:** LLMs can be used maliciously

Q36: AI Nontechnical Risk

Question

Which is an example of a nontechnical risk that enterprises may overlook when using AI?

A. Software bugs
B. Biased or incorrect outputs impacting human rights and safety
C. Unpatched vulnerabilities
D. Network latency

Q36: Explanation

Correct Answer: B

AI presents nontechnical risk, notably ethical and environmental impacts. Biased outputs that impact human rights and safety can result in reputational and legal damage.

Option Analysis

- **A** - **Incorrect:** Software bugs are technical risk
- **B** - **Correct:** Ethical/bias impacts
- **C** - **Incorrect:** Unpatched vulnerabilities are technical
- **D** - **Incorrect:** Network latency is technical

Q37: Quantum Computing Impact

Question

The MOST critical concern related to quantum computing for all organizations is its impact on:

A. Job displacement
B. Applied cryptography
C. Supply chain vulnerabilities
D. Power generation sustainability

Q37: Explanation

Correct Answer: B

The most critical concern is quantum computing's impact on applied cryptography. Encryption used to secure transactions and sensitive information will effectively become obsolete once quantum computers become mainstream.

Option Analysis

- **A - Incorrect:** A concern but not the most universal
- **B - Correct:** Cryptography impact affects all
- **C - Incorrect:** A concern but not most critical
- **D - Incorrect:** A concern but not most critical

Q38: Deepfake Social Engineering

Question

Which emerging technology poses a substantial challenge for organizations that authorize financial transfers based on verbal approval?

A. Big data analytics
B. Deepfake technology
C. Blockchain
D. Internet of Things

Q38: Explanation

Correct Answer: B

Deepfake technology can create convincing audio and video imitations, challenging organizations that authorize financial transfers based on verbal or visual approval. Real-world examples include wire transfers after deepfake video calls.

Option Analysis

- **A - Incorrect:** Not a deception technology
- **B - Correct:** Deepfakes enable impersonation
- **C - Incorrect:** Blockchain is a ledger technology
- **D - Incorrect:** IoT is about connected devices

Q39: Blockchain Characteristic

Question

Which characteristic makes it very difficult to falsify an entry in a blockchain?

A. Each entry is stored on a single central server

B. Each entry contains both its own digital hash and the hash of the block before it

C. Entries are encrypted with symmetric keys only

D. Entries are never verified

Q39: Explanation

Correct Answer: B

The chain structure makes falsification difficult because each entry contains both its own hash and the hash of the previous block. Decentralization provides transparency.

Option Analysis

- **A - Incorrect:** Blockchain is decentralized
- **B - Correct:** Chained hashes
- **C - Incorrect:** Uses cryptographic hashing
- **D - Incorrect:** Entries are verified through consensus

Q40: IoT Device Risk

Question

Why do IoT devices pose a significant risk in enterprise environments?

- (A) They always have strong security features
- (B) They tend to prioritize functionality over security, and their presence may become known only after deployment
- (C) They are always managed by IT from the start
- (D) They cannot be hacked

Q40: Explanation

Correct Answer: B

IoT devices tend to prioritize functionality over security. Their presence may become known to security staff only after deployment, leaving enterprises reliant on compensating controls.

Option Analysis

- **A - Incorrect:** IoT often lacks strong security
- **B - Correct:** Functionality over security, unknown deployment
- **C - Incorrect:** IoT often managed by facilities
- **D - Incorrect:** IoT devices can be hacked

Q41: Omnipresent Connectivity Risk

Question

Why does omnipresent connectivity make it harder to safeguard information?

A. People are less able to share information

B. People are more able and more inclined to share information, including on social media

C. Connectivity has no effect on information sharing

D. All data is automatically encrypted

Q41: Explanation

Correct Answer: B

People are both more able to share information and more inclined to do so, including livestream video feeds taken without notice to those around them.

Option Analysis

- **A - Incorrect:** People are more able to share
- **B - Correct:** Increased sharing tendency
- **C - Incorrect:** Connectivity affects sharing
- **D - Incorrect:** Not all data is encrypted

Q42: Big Data Challenge - Data Ownership

Question

Which is a common challenge enterprises face associated with big data?

A. Data ownership is often not clearly defined
B. Data is always perfectly organized
C. Regulatory requirements are decreasing
D. There is an abundance of skilled data analysts

Q42: Explanation

Correct Answer: A

A common challenge is that data ownership is often not clearly defined due to the misconception that data management is technical work. Other challenges include siloed structures, data deluge, lack of skilled analysts, and AI-related data biases.

Option Analysis

- **A - Correct:** Data ownership is often unclear
- **B - Incorrect:** Big data is often disorganized
- **C - Incorrect:** Data regulations are trending upward
- **D - Incorrect:** There is a shortage of skilled analysts

Technology Risk Key Takeaways

Essential Concepts

- EA provides current state, future vision, and a strategy to move between them
- Technology roadmaps link business goals to technology solutions
- Hardware risk: obsolescence, misconfiguration, default credentials
- OS risk: kernel-level vulnerabilities, unpatched flaws, end of support
- Cloud risk: reduced visibility, vendor lock-in, provider insiders
- IDS detects and alerts; IPS detects and blocks in-line
- Zero trust protects resources, not network segments
- Emerging tech introduces new risk categories
- Big data amplifies impact through centralization

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each technology risk concept
- Know the difference between similar terms
- Understand how emerging technologies introduce new risk
- Practice scenario-based questions
- Use the ISACA mindset

Good Luck on Your CRISC Exam!